

CHƯƠNG 8

Chiếm phiên làm việc

Nội dung

- Khái niệm chung
- Các kỹ thuật chính
- Tiến trình thực hiện
- Kiểu chiếm phiên làm việc
- Chiếm phiên làm việc tầng ứng dụng
- Chiếm phiên làm việc tầng mạng
- Công cụ thực hiện
- Biện pháp phòng chống
- Kiểm thử hệ thống

Khái niệm chung

What is Session Hijacking?

Session Hijacking refers to the exploitation of a **valid computer session** where an attacker takes over a session between two computers



The attacker steals a valid session ID which is used to get into the **system and snoop the data**

In TCP session hijacking, an attacker takes over a **TCP session** between two machines



Since most **authentication only occurs at the start of a TCP session**, this allows the attacker to gain access to a machine



Khái niệm chung

Dangers Posed by **Hijacking**

Most countermeasures do not work unless you use encryption

Hijacking is simple to launch

Threat of identity theft, information loss, fraud, etc.

You can do little to protect against it unless you switch to another secure protocol



Most computers using TCP/IP are vulnerable

Khái niệm chung

Why **Session Hijacking** is Successful?



No Account Lockout For Invalid Session Ids

Weak Session ID Generation Algorithm

Insecure Handling

Indefinite Session Expiration Time

Small Session Ids

Clear Text Transmission



Các kỹ thuật chính

Brute Forcing

The attacker attempts different IDs until he succeeds



Stealing

Attacker uses different techniques to steal Session IDs



Calculating

Using non-randomly generated IDs, an attacker tries to calculate the Session IDs



Các kỹ thuật chính

Brute Forcing

Using **brute force attacks**, an attacker tries to guess **session ID** until he guesses the session ID



For example, in the URL's, an attacker is trying to guess the session ID

`http://www.mysite.com/view/VW30422101518909`
`http://www.mysite.com/view/VW30422101520803`
`http://www.mysite.com/view/VW30422101522507`



Session ID's can be stolen using different techniques such as:

1. Using the HTTP referrer header
2. Sniffing the network traffic
3. Using the Cross-Site Scripting attacks
4. Sending Trojans on client PCs

1. Using a "**referrer attack**", an attacker tries to lure a user to click on a link to another site (a mysite link, say `www.mysite.com`)
2. For example, GET /index.html HTTP/1.0 Host: `www.mysite.com` Referrer: `www.mywebmail.com/viewmsg.asp?msgid=689645&SID=2556X54VA75`
3. The attacker obtains the session ID of the user by sending when the **browser sends the referrer URL** that contains the session ID of the user to the attacker's site (`www.mysite.com`)

Các kỹ thuật chính

Brute Forcing Attack

- Using **brute force attacks**, an attacker tries to guess **session ID** until he finds the correct session ID
- Possible range of values for the session ID must be **limited** to perform a successful bruteforce attack



Các kỹ thuật chính

HTTP Referrer Attack



In a referrer attack, attacker tries to **lure a user** to click on a link to another site (a mysite link, say www.mysite.com)



For example, `GET /index.html HTTP/1.0 Host: www.mysite.com Referrer: www.mywebmail.com/viewmsg.asp?msgid=689645&SID=2556X54VA75`



The browser **sends the referrer URL** containing the session ID to the attacker's site - www.hostile.com, and the attacker now has the session ID of the user

Các kỹ thuật chính

Spoofing vs. Hijacking

Spoofing Attack

Attacker **pretends to be another user** or machine (victim) to gain access

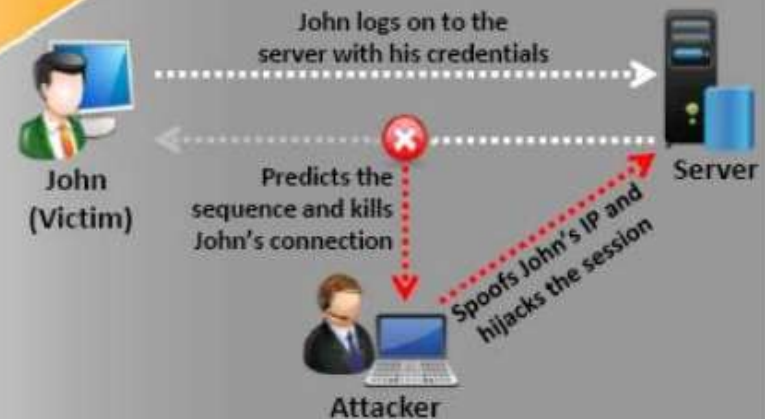
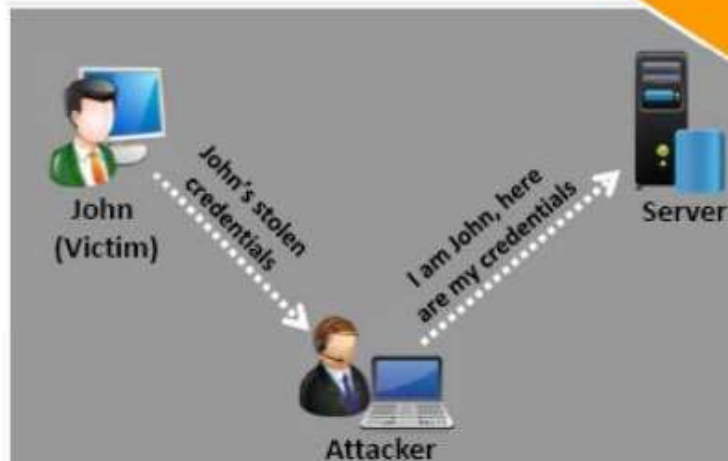
Attacker does not take over an existing active session. Instead he initiates a new session using victim's **stolen credentials**



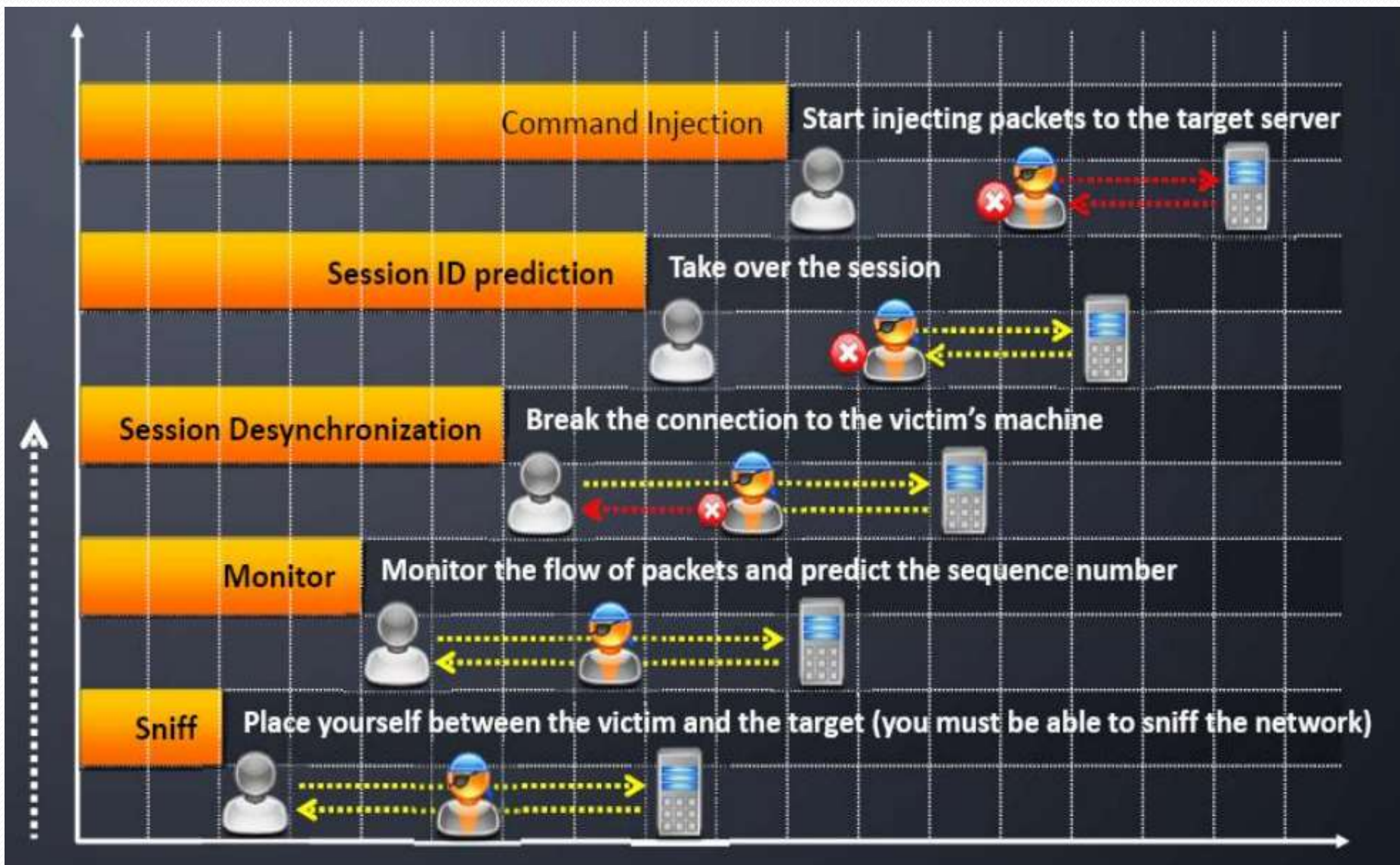
Hijacking

Session hijacking is the process of taking over an **existing active session**

Attacker relies on the **legitimate user** to make a connection and authenticate



Tiến trình thực hiện



Tiến trình thực hiện

Packet Analysis of a Local Session Hijack



SYN <Clt ISN 4000><WIN 512>



SYN <Svr ISN 5000><WIN 1024> /ACK 4001

ACK 4001

DATA=128 <Clt SEQ 4001>

ACK (Clt SEQ + DATA) 4129

DATA=91 <Clt SEQ 4129>

ACK (Clt SEQ + DATA) 4220

Kiểu của Session Hijacking



Kiểu của Session Hijacking

Session Hijacking in OSI Model



Network Level Hijacking

- Network level can be defined as the **interception of the packets** during the transmission between the client and the server in a TCP and UDP session



Application Level Hijacking

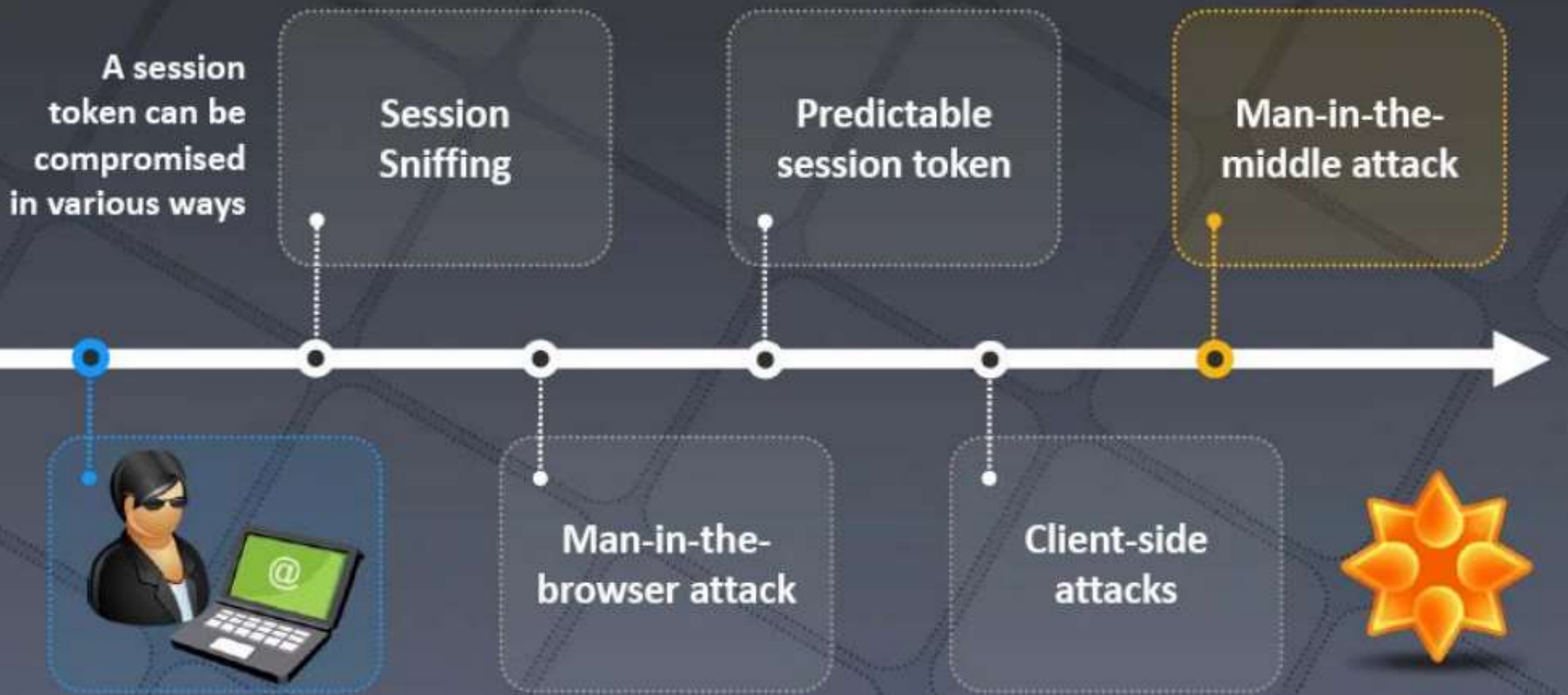
- Application level is about **gaining control** on the **HTTP's user session** by obtaining the session ID's



Session Hijacking tầng ứng dụng

Application Level Session Hijacking

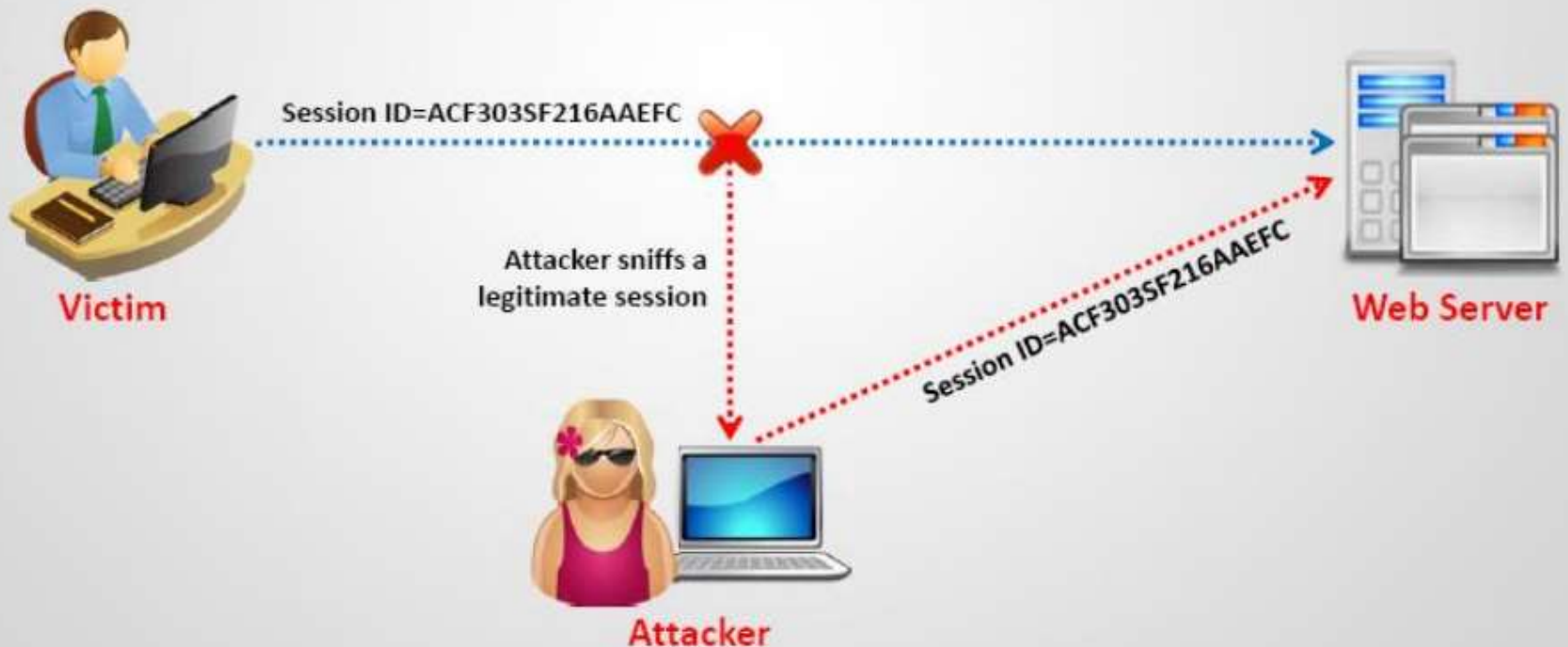
In a Session Hijacking attack, a session token is stolen or a valid session token is predicted to **gain unauthorized access** to the web server



Session Hijacking tầng ứng dụng

Session Sniffing

- Attacker uses a sniffer to **capture a valid session token** called "Session ID"
- Attacker then uses the valid token session to **gain unauthorized access** to the web server



Session Hijacking tầng ứng dụng

Predictable Session Token

It is a method used for predicting a session ID or to **impersonate a web site user**

Predicting a session ID is also known as **Session Hijacking**

Using session hijacking technique, an attacker gets the ability to **ping web site requests** with compromised user's privileges

By guessing the **unique session value** or **deducing** the session ID accomplishes the attack



Session Hijacking tầng ứng dụng

How to Predict a **Session Token**?

Most of the webservers use custom **algorithms** or a predefined pattern to generate sessions IDs



Captures

Attacker captures several session IDs and analyzes the pattern

```
http://www.juggyboy.com/view/JBEX21092010152820
http://www.juggyboy.com/view/JBEX21092010153020
http://www.juggyboy.com/view/JBEX21092010160020
http://www.juggyboy.com/view/JBEX21092010164020
```

Constant Date Time



Predicts

At 16:25:55 on Sep-25, 2010, attacker can successfully predict the session ID to be

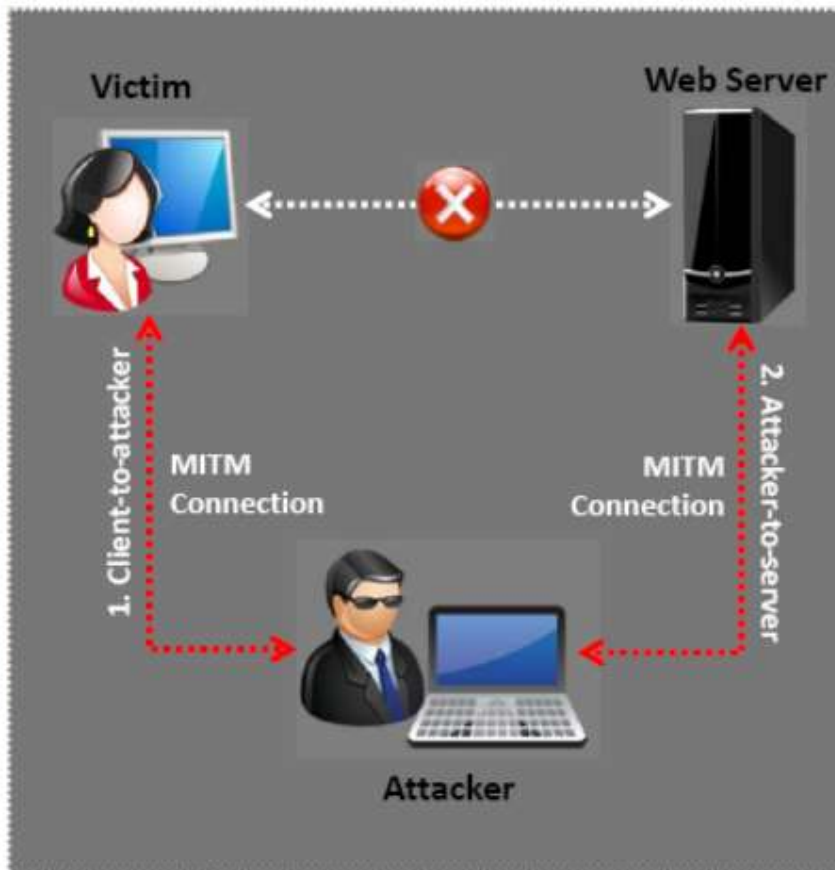
```
http://www.juggyboy.com/view/JBEX25092010162555
```

Constant Date Time

Session Hijacking tầng ứng dụng

Man-in-the-Middle Attack

The man-in-the-middle attack is used to **intrude into an existing connection** between systems and to intercept messages being exchanged



Attackers use different techniques and **split the TCP connection** into two connections

1. Client-to-attacker connection
2. Attacker-to-server connection

After the successful interception of TCP connection, an attacker can read, modify, and insert fraudulent data into the **intercepted communication**

In the case of an **http transaction**, the TCP connection between the client and the server becomes the target

Session Hijacking tầng ứng dụng

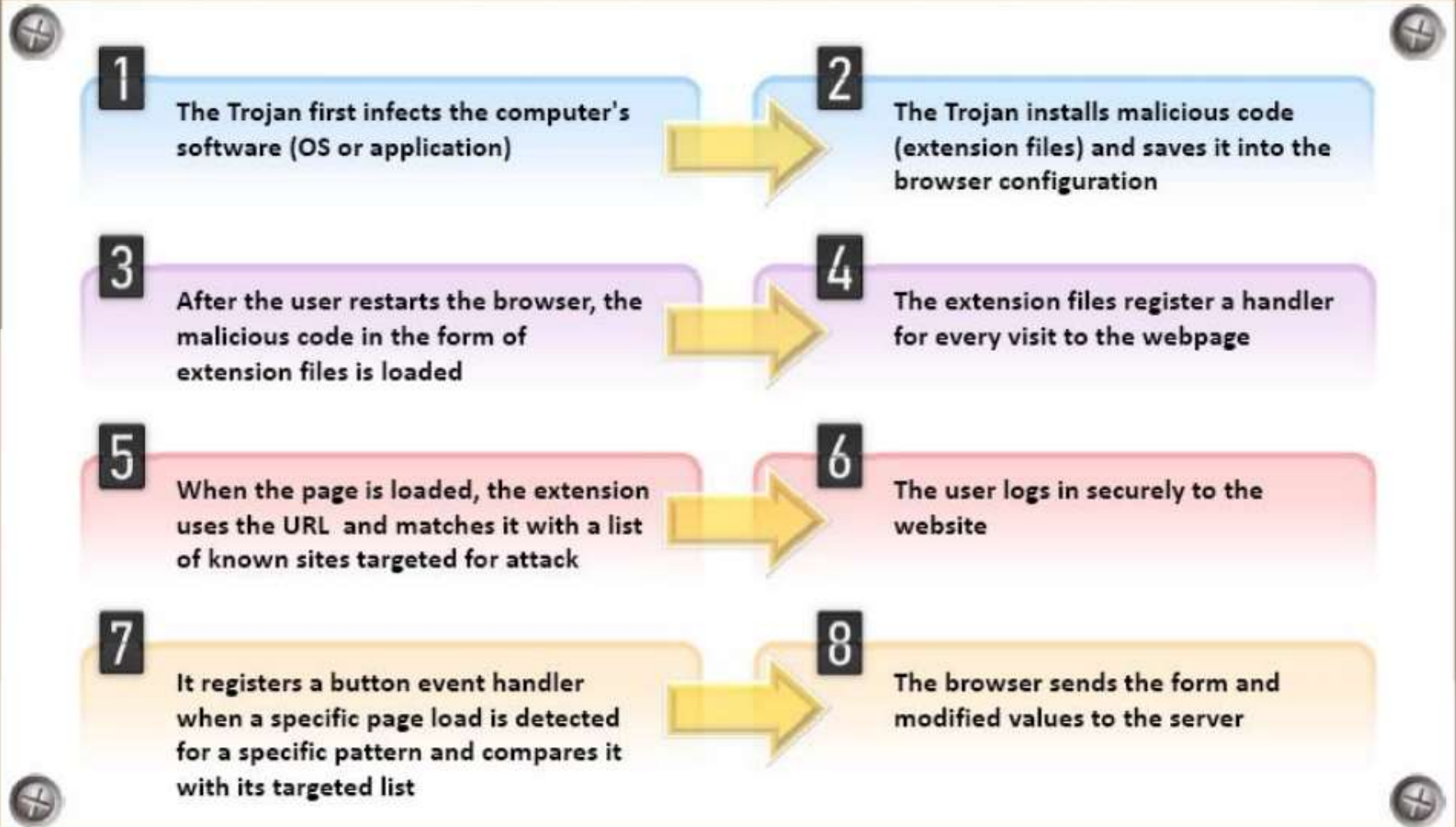
Man-in-the-Browser Attack

- Man-in-the-browser attack **uses a Trojan Horse** to intercept the calls between the browser and its security mechanisms or libraries
- It works with an already installed Trojan horse and acts between the **browser and its security mechanisms**
- Its main objective is to cause financial deceptions by manipulating transactions of Internet Banking systems



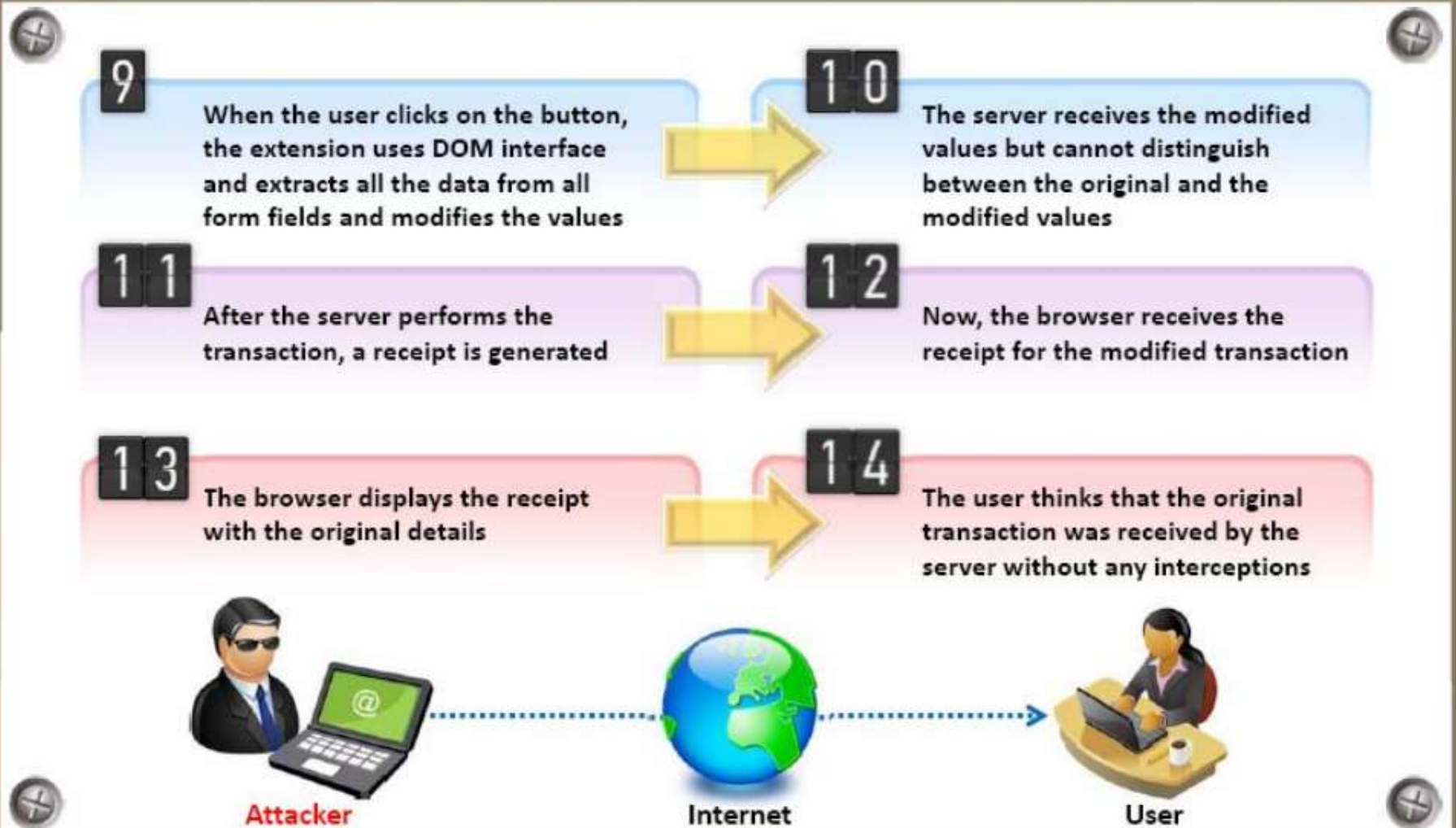
Session Hijacking tầng ứng dụng

Steps to Perform **Man-in-the-Browser Attack**



Session Hijacking tầng ứng dụng

Steps to Perform **Man-in-the-Browser Attack**



Session Hijacking tầng ứng dụng

Client-side Attacks

XSS

Cross-Site Scripting attacks are a type of injection attacks, in which the malicious scripts are injected into the web sites

Malicious
JavaScript Codes

A malicious script can be embedded in a web page and does not generate any type of warnings when the page is viewed in any browser

Trojans

Trojan horse is a program in which the malicious code is contained inside apparently harmless programming or data in such a way that it can get control and cause damage



Session Hijacking tầng ứng dụng

Cross-site Script Attack

The attacker can compromise the session token by sending malicious code or programs to **the client-side programs**

The example here shows how the attacker steals the session token using **XSS attack**

If an attacker sends a crafted link to the victim with the **malicious JavaScript**, when the victim clicks on the link, the JavaScript will run and complete the instructions made by the attacker

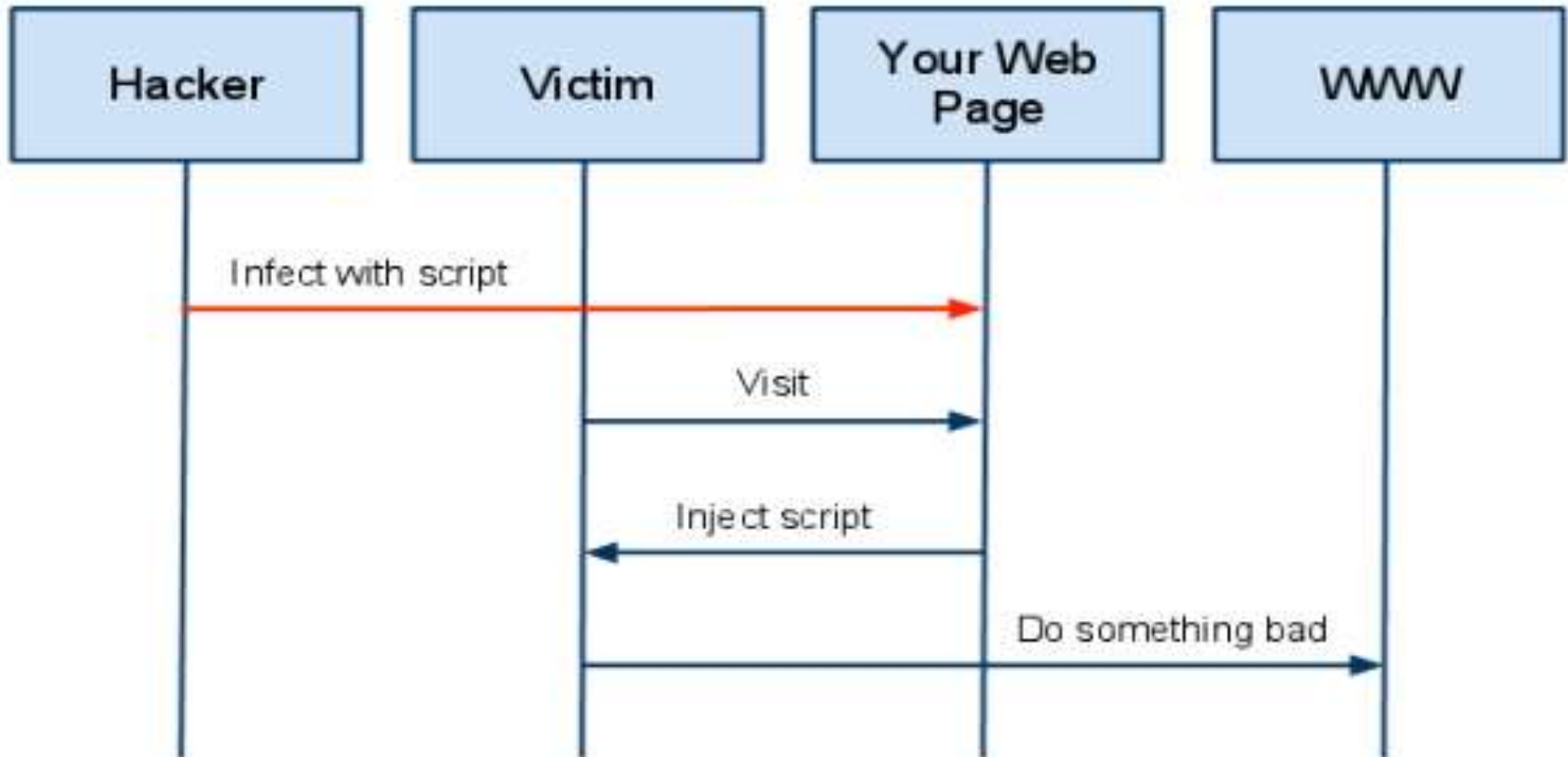
The example here uses an XSS attack to show the **cookie value** of the current session

Using the same technique, it is possible to create a specific JavaScript code that will send the cookie to the attacker **<SCRIPT>alert (document.cookie) ;</SCRIPT>**



Session Hijacking tầng ứng dụng

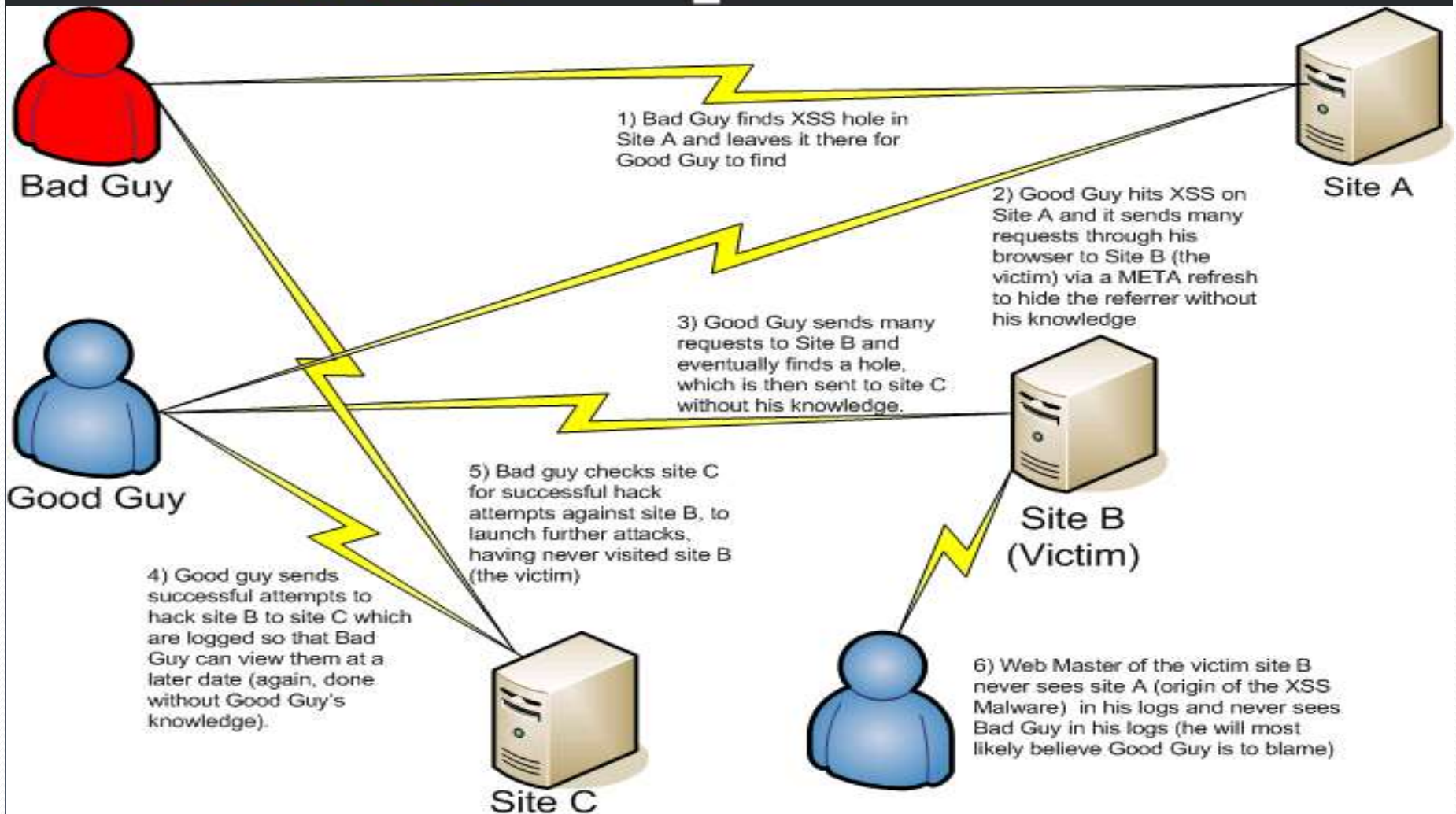
Cross-site Script Attack



A High Level View of a typical XSS Attack

Session Hijacking tầng ứng dụng

Cross-site Script Attack



Session Hijacking tầng ứng dụng

Session **Fixation**



Session Fixation is an attack that allows an attacker to hijack a **valid user session**



The attack tries to lure a user to authenticate himself with a known session ID and then hijacks the **user-validated session** by the knowledge of the used session ID



The attacker has to provide a **legitimate web application** session ID and try to lure victim browser to use it

Several techniques to **execute Session Fixation** attack are

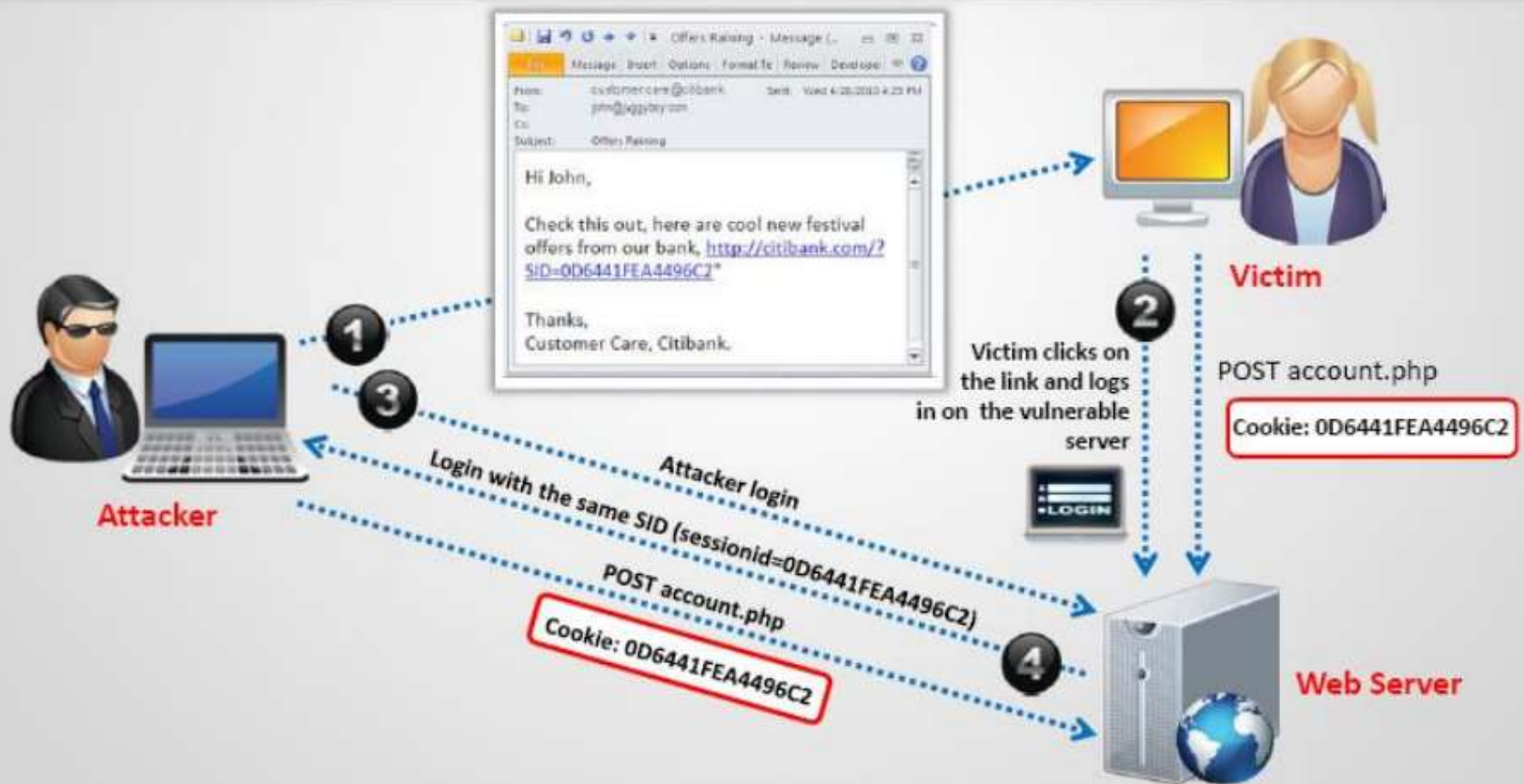


- Session token in the **URL argument**
- Session token in a **hidden form field**
- Session ID in a **cookie**

Session Hijacking tầng ứng dụng

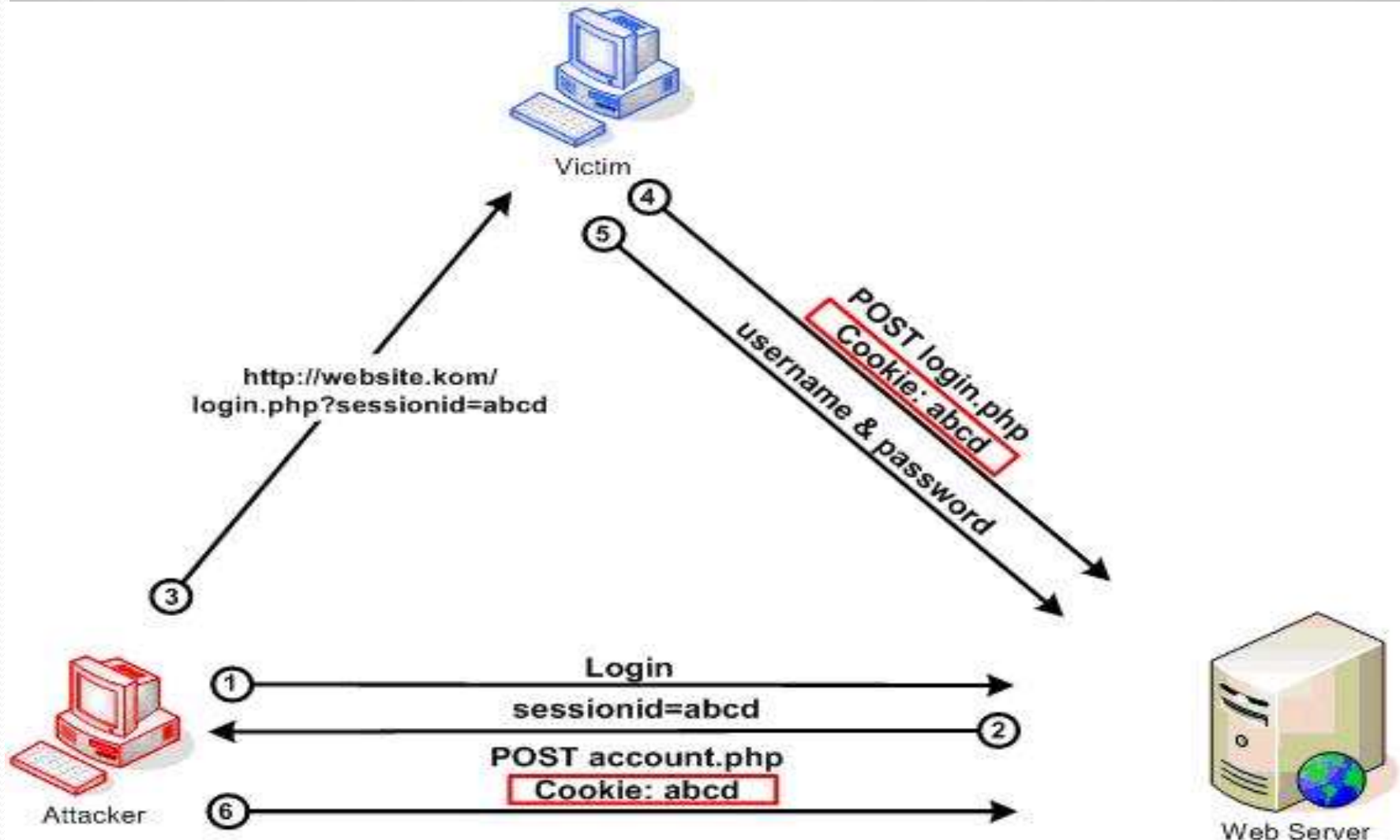
Session Fixation Attack

- Attacker exploits the **vulnerability of a server** which allows a user to use fixed SID
- Attacker provides a **valid SID** to a victim and lures him to **authenticate himself** using that SID



Session Hijacking tầng ứng dụng

Session Fixation Attack



Session Hijacking tầng mạng

- The network level hijacking is **implemented on the data flow of the protocol** shared by all web applications
- By attacking the network level sessions, the attacker gathers some **critical information** which is used to **attack the application level sessions**

Network level hijacking includes:

Blind Hijacking

TCP/IP Hijacking

UDP Hijacking

RST Hijacking

Man in the Middle:
Packet Sniffer

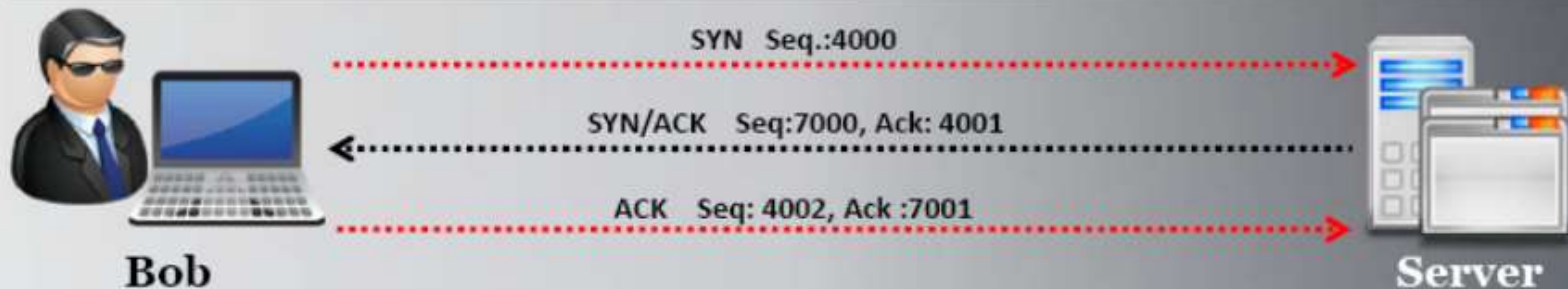
IP Spoofing: Source
Routed Packets



Session Hijacking tầng mạng

The 3-Way Handshake

If the attacker can anticipate the **next sequence** and **ACK number** that Bob will send, he/she will **spoof** Bob's address and start a communication with the server



1. Bob initiates a connection with the server and sends a packet to the server with the **SYN bit set**
2. The server receives this packet and sends back a packet with the **SYN/ACK bit** and an **ISN (Initial Sequence Number)** for the server
3. Bob sets the **ACK bit** acknowledging the receipt of the packet and increments the sequence number by 1
4. Now, the two machines successfully **established a session**



Session Hijacking tầng mạng

Sequence Numbers



Sequence numbers are important in providing a reliable communication and are also crucial for hijacking a session



They are a 32-bit counter. Therefore, the possible combinations can be over 4 billion



They are used to tell the receiving machine in what order the packets should go when they are received



Therefore, an attacker must successfully guess the sequence numbers in order to hijack a session



Session Hijacking tầng mạng

Sequence Number Prediction



After a client sends a connection request (SYN) packet to the server, the server responds (SYN-ACK) with a sequence number of choosing, which must be acknowledged by the client

This sequence number is predictable; the attack connects to a server first with its own IP address, records the sequence number chosen, and then opens a second connection from a forged IP address



If the source IP address is used for authentication, then the attacker can use one-sided communication to break into the server

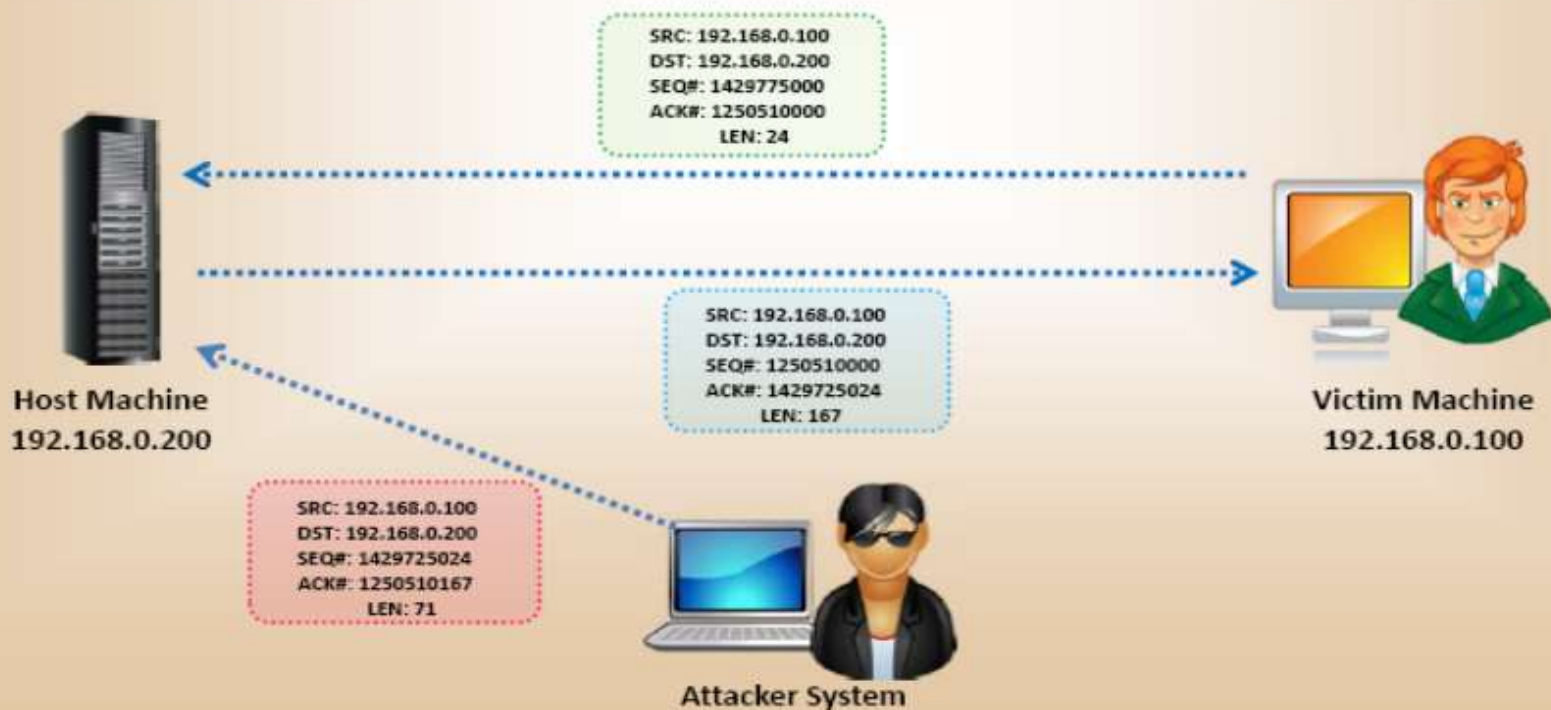
The attack does not see the SYN-ACK (or any other packet) from the server, but can guess the correct response



Session Hijacking tầng mạng

TCP/IP Hijacking

- TCP/IP hijacking is a hacking technique that uses **spoofed packets** to take over a connection between a victim and a target machine
- The victim's connection hangs and the attacker is then able to **communicate with the host's machine** as if the attacker is the victim
- To launch a TCP/IP hijacking attack, the **attacker must be on the same network as the victim**
- The target and the victim machines can be anywhere



Session Hijacking tầng mạng

TCP/IP Hijacking

1

Attacker sniffs the victim's connection and uses victim's IP to send a spoofed packet with the predicted sequence number

2

Host processes the **spoofed packet**, increments the sequence number and sends acknowledgement to the victim's IP

3

Victim machine is unaware of the spoofed packet, so it ignores the host machine's **ACK packet** and turns sequence number count off

4

Therefore, the host receives packets with the incorrect sequence number

5

The attacker forces the victim's connection with the host machine to a **desynchronized state**

6

The attacker **tracks sequence numbers** and continuously spoofs packets that comes from the victim's IP

7

The attacker continues to communicate with the **host machine** while the victim's connection hangs



Session Hijacking tầng mạng

IP Spoofing: Source Routed Packets



Source Routed Packets technique is used for **gaining unauthorized access** to the computer with the aid of the trusted host's IP address



The host's IP address spoofs the packets so that the server **managing a session** with the client, accepts the packets



When the session is established, the hijacker **injects the forged packets** before the client responds



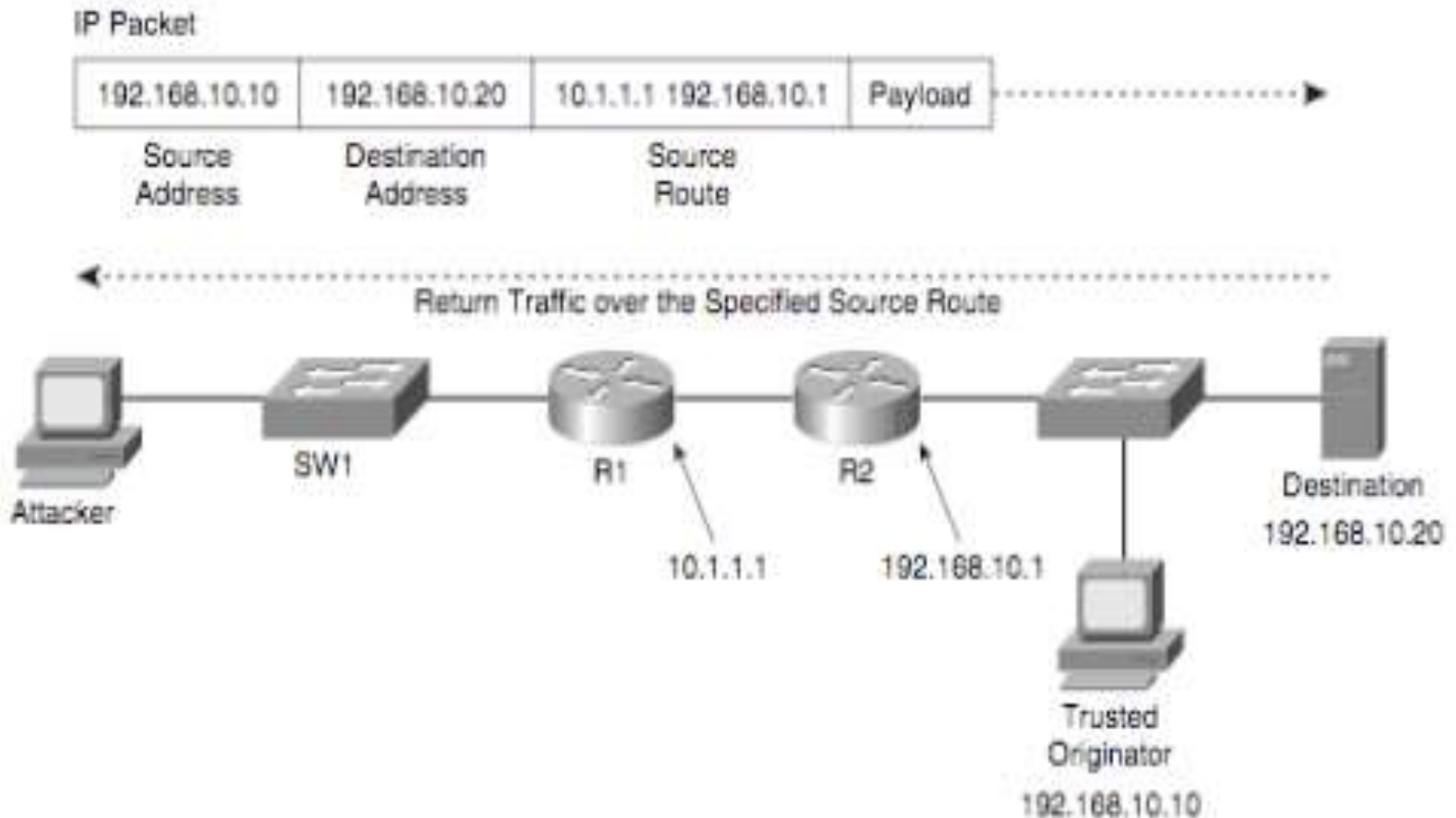
The original packet is lost as the server gets the packet with a **different sequence number**



The packets are source-routed where the patch to the **destination IP** can be specified by the attacker

Session Hijacking tầng mạng

IP Spoofing: Source Routed Packets



Session Hijacking tầng mạng

RST Hijacking

1

RST hijacking involves injecting an authentic-looking reset (RST) packet using spoofed source address and predicting the acknowledgment number

2

The victim believes that the source actually sent the reset packet and resets the connection

RST packet

Spoofed source address
with predicted ACK number

2

1

Connection reset



Victim



Attacker

RST Hijacking can be carried out using a packet crafting tool such as Colasoft's Packet Builder and TCP/IP analysis tool such as tcpdump

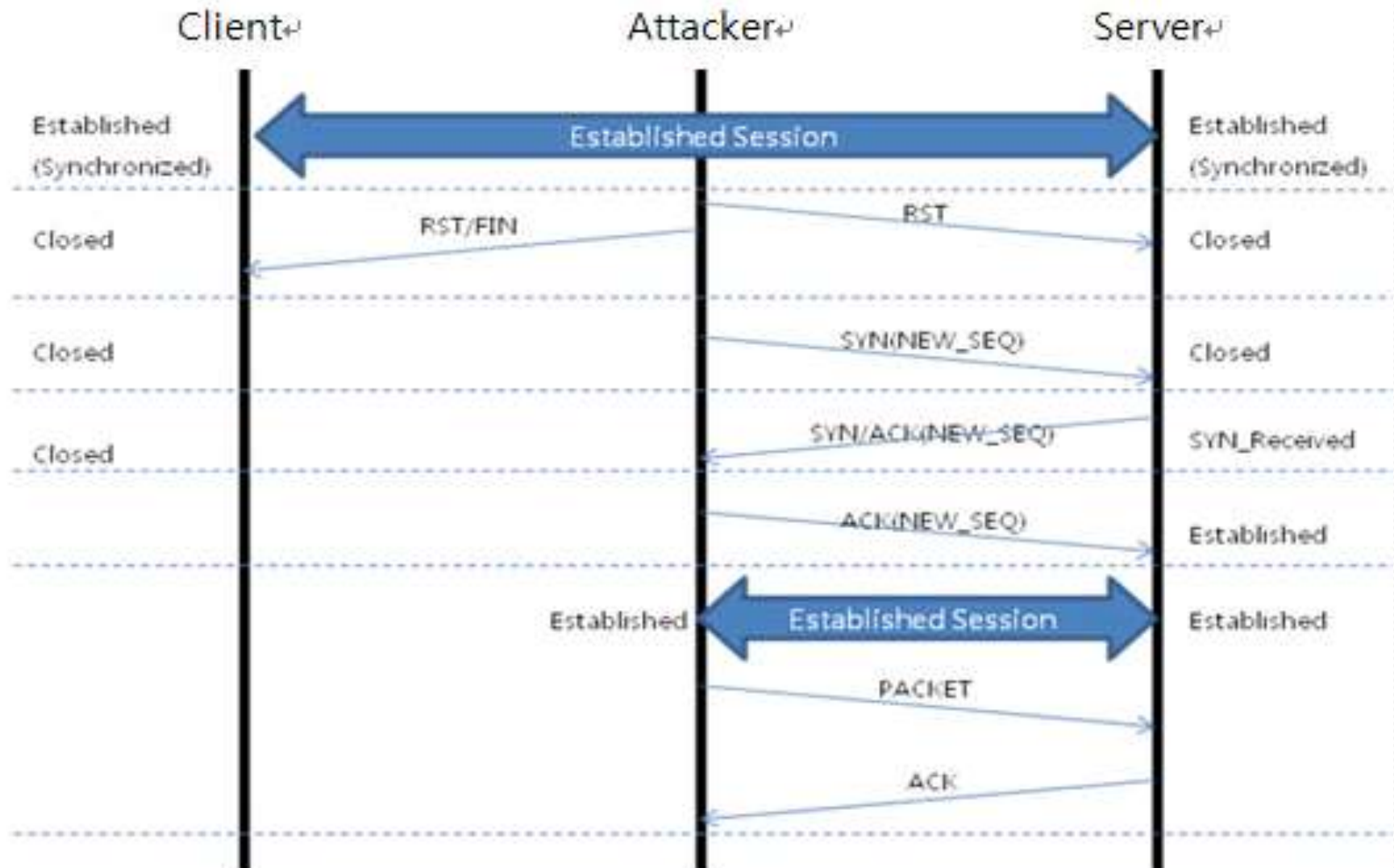
Turn on the ACK flag in tcpdump to sniff the packets

4

3

Session Hijacking tầng mạng

RST Hijacking



Session Hijacking tầng mạng

Blind Hijacking

- 🕒 The attacker can inject the **malicious data or commands** into the intercepted communications in the TCP session even if the source-routing is disabled
- 🕒 The attacker can send the data or comments but has no **access to see the response**



Session Hijacking tầng mạng

Man-in-the-Middle Attack using Packet Sniffer

In this attack, the packet sniffer is used as an interface between the **client and the server**

The packets between the client and the server are routed through the hijacker's host by using two techniques

Using forged Internet Control Message Protocol (ICMP) –
It is an extension of IP to send error messages where the attacker can send messages to fool the client and the server

Using Address Resolution Protocol(ARP) spoofing –
ARP is used to map the local IP addresses to hardware addresses or MAC addresses

ARP spoofing involves fooling the host by **broadcasting the ARP request** and changing its ARP tables by sending the forged ARP replies



Session Hijacking tầng mạng

UDP Hijacking

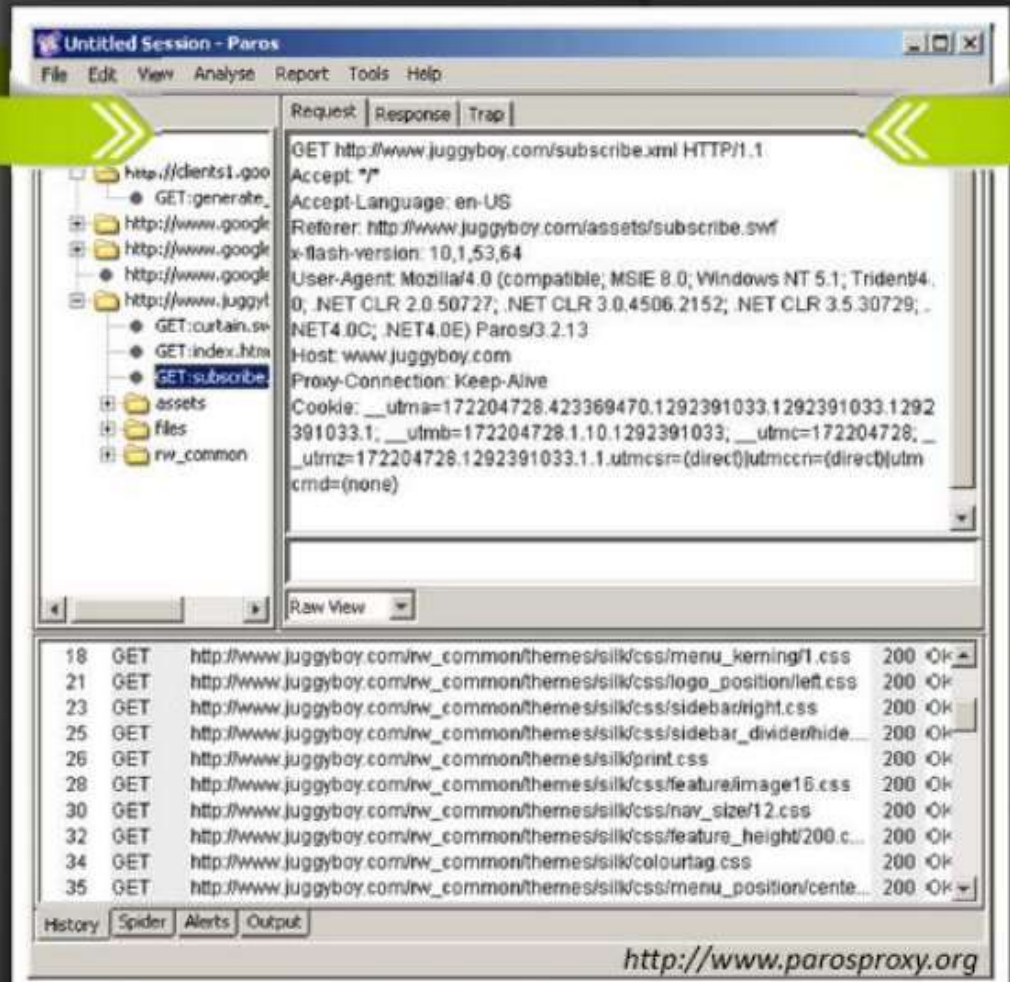
1. Attacker sends a **forged server reply** to the client's UDP request before the server responds to it
2. Attacker uses **Man-in-the-Middle** attack to intercept server's response to the client and sends its own forged reply



Công cụ thực hiện Session Hijacking

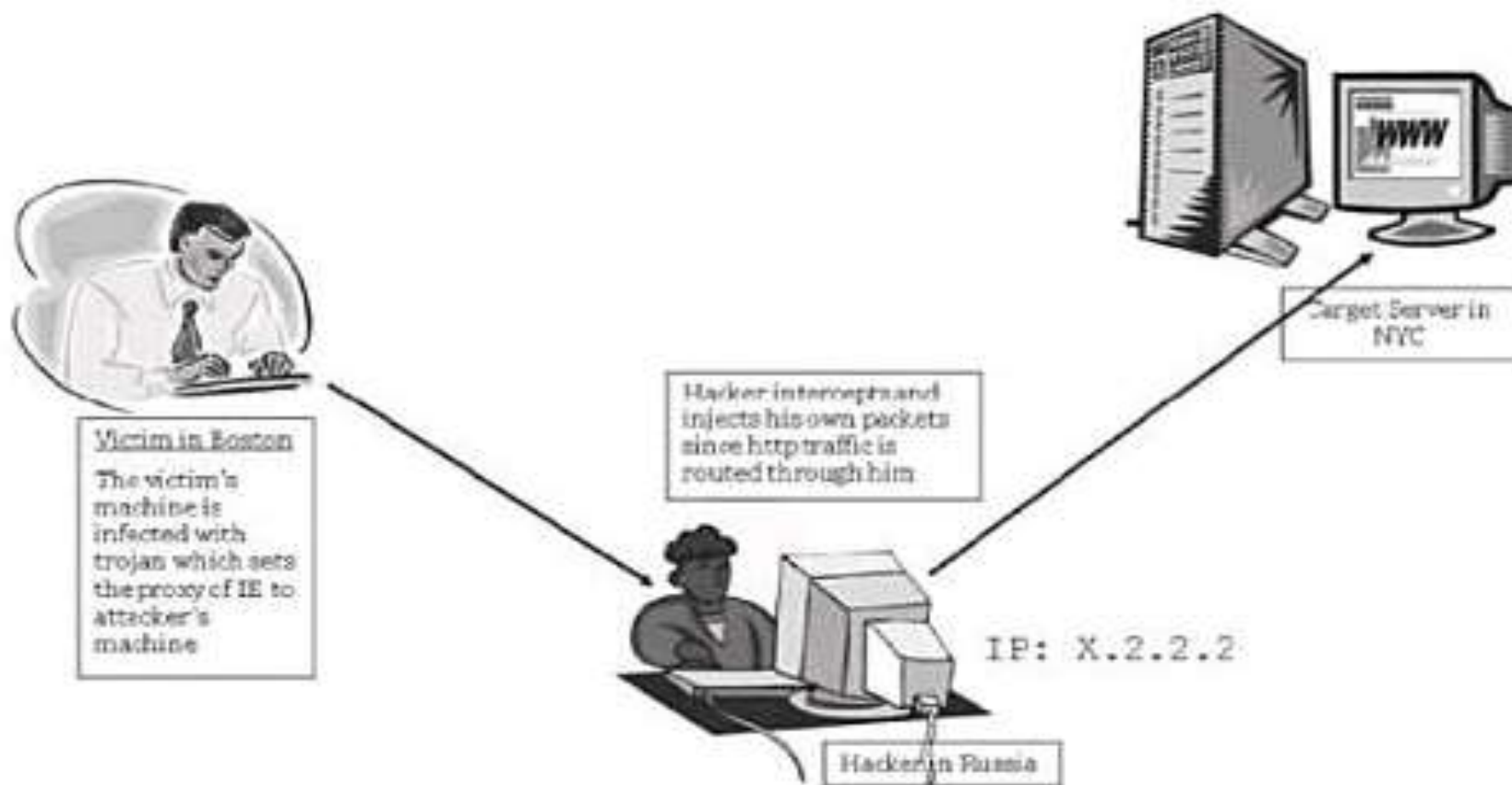
Session Hijacking Tool: **Paros**

- Paros is a man-in-the-middle proxy and application vulnerability scanner
- It allows attacker to **intercept, modify, and debug HTTP and HTTPS data** on-the-fly between a web server and a client browser
- It also supports spidering, proxy-chaining, filtering, and application vulnerability scanning



Công cụ thực hiện Session Hijacking

● Session Hijacking Tool: **Paros**

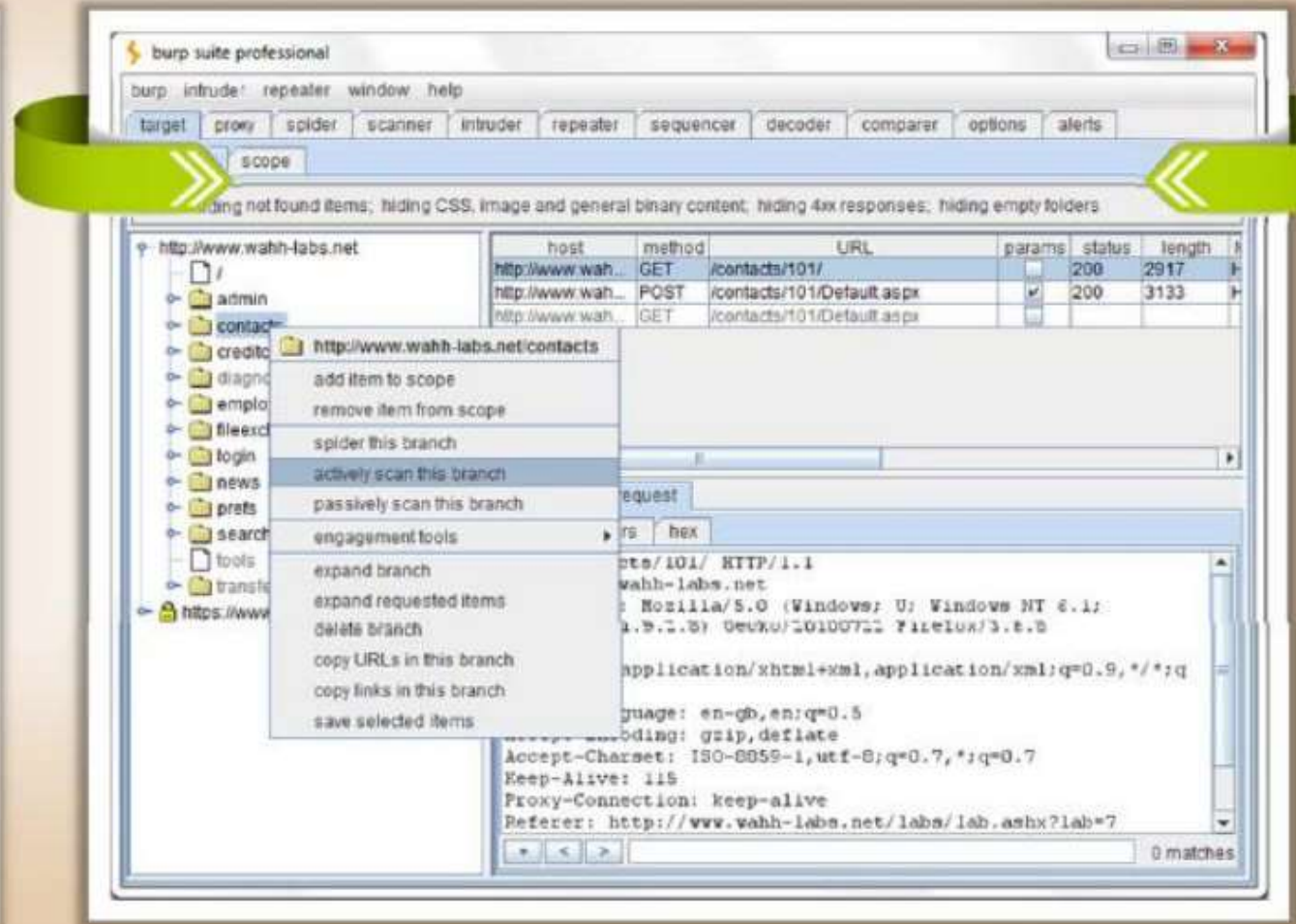


This is how the Paros HTTP Session Hijacking Tool works.

Công cụ thực hiện Session Hijacking

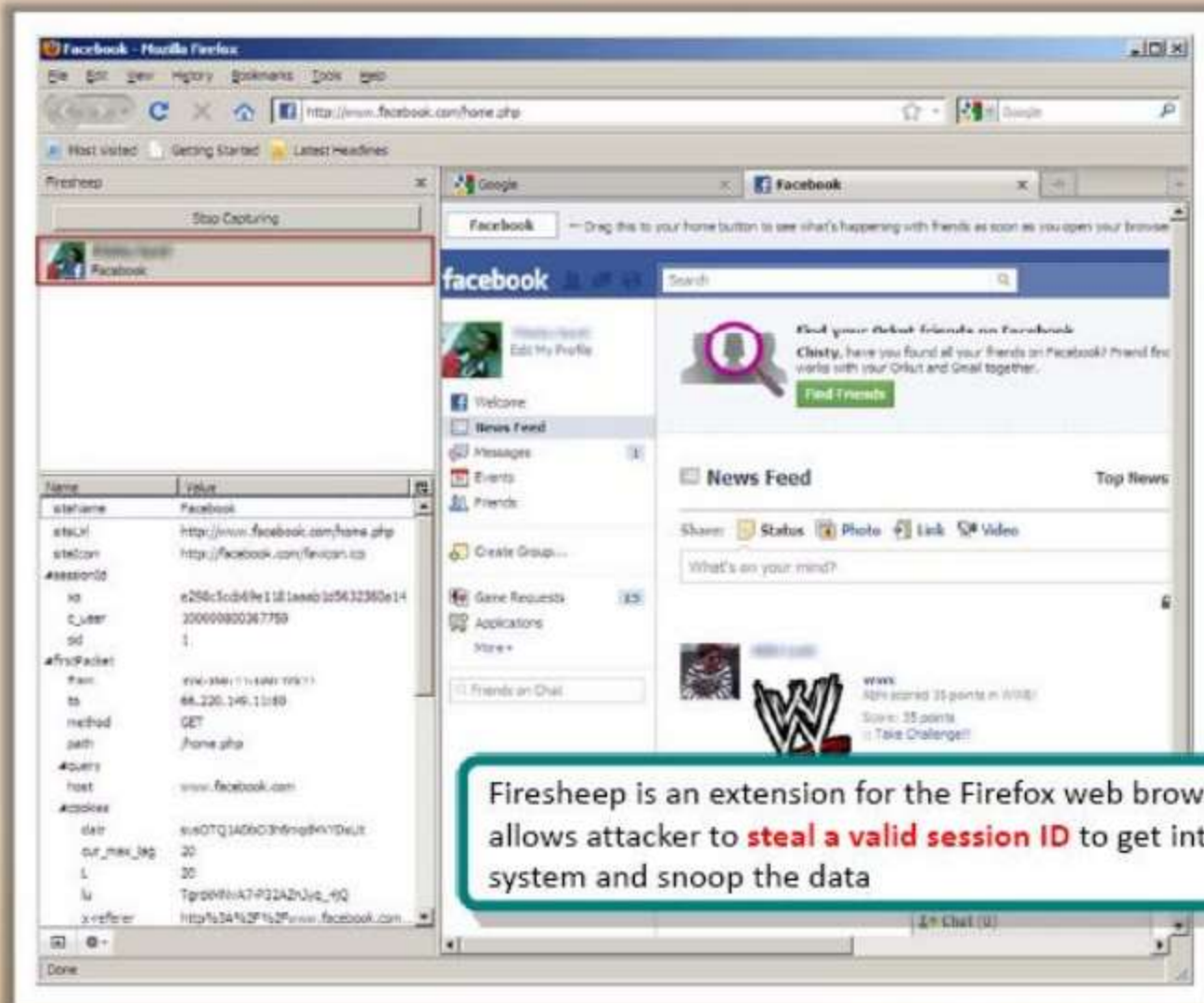
Session Hijacking Tool: **Burp Suite**

- Burp suite allows attacker to **inspect and modify traffic** between browser and the target application
- It **analyzes** all kinds of content, with automatic colorizing of request and response syntax



Công cụ thực hiện Session Hijacking

Session Hijacking Tool: **Firesheep**



Firesheep is an extension for the Firefox web browser which allows attacker to **steal a valid session ID** to get into the system and snoop the data

Công cụ thực hiện Session Hijacking

Add-on "**Firesheep**", được Eric Butler - một nhà phát triển ứng dụng web tự do sống tại Seattle (Mỹ) - phát hành hôm Chủ Nhật 24/10/2010 tại hội nghị bảo mật **ToorCon**. ToorCon đã diễn ra từ ngày 22 - 24/10/2010 tại San Diego (Mỹ). Ông cho biết đã tạo ra Firesheep để cho thấy sự nguy hiểm của việc truy cập các website không được mã hóa từ các điểm truy cập Wi-Fi công cộng.

Với cookie của người dùng trong tay, một tên tội phạm có thể làm bất cứ điều gì người dùng có thể làm trên website. Trong số các website mà Firesheep có thể "*cướp*" được quyền truy cập, phải kể tới Facebook, Twitter, Flickr, bit.ly, Google và Amazon.

Firesheep thêm một thanh sidebar cho trình duyệt Firefox của Mozilla, hiển thị thông tin khi có ai đó trên một mạng mở - như mạng Wi-Fi của quán cà phê chẳng hạn - đang thăm một website không an toàn. "*Click kép vào ai đó trong sidebar và bạn ngay lập tức đăng nhập như họ*".

Công cụ thực hiện Session Hijacking

Session Hijacking Tools



Hamster

<http://hamster.erratasec.com>



Hunt

<http://packetstormsecurity.org>



Session Thief

<http://scriptjunkie1.110mb.com>



JHijack

<http://jhijack.sourceforge.net>



Surf Jack

<http://surfjack.googlecode.com>



TamperIE

<http://www.bayden.com>



Ettercap

<http://ettercap.sourceforge.net>



Ferret

<http://www.erratasec.com>

Biện pháp phòng chống



Countermeasures



Use secure shell (SSL) to create a secure communication channel



Pass the authentication cookies over HTTPS connection



Implement the logout functionality for user to end the session



Generate the session ID after successful login



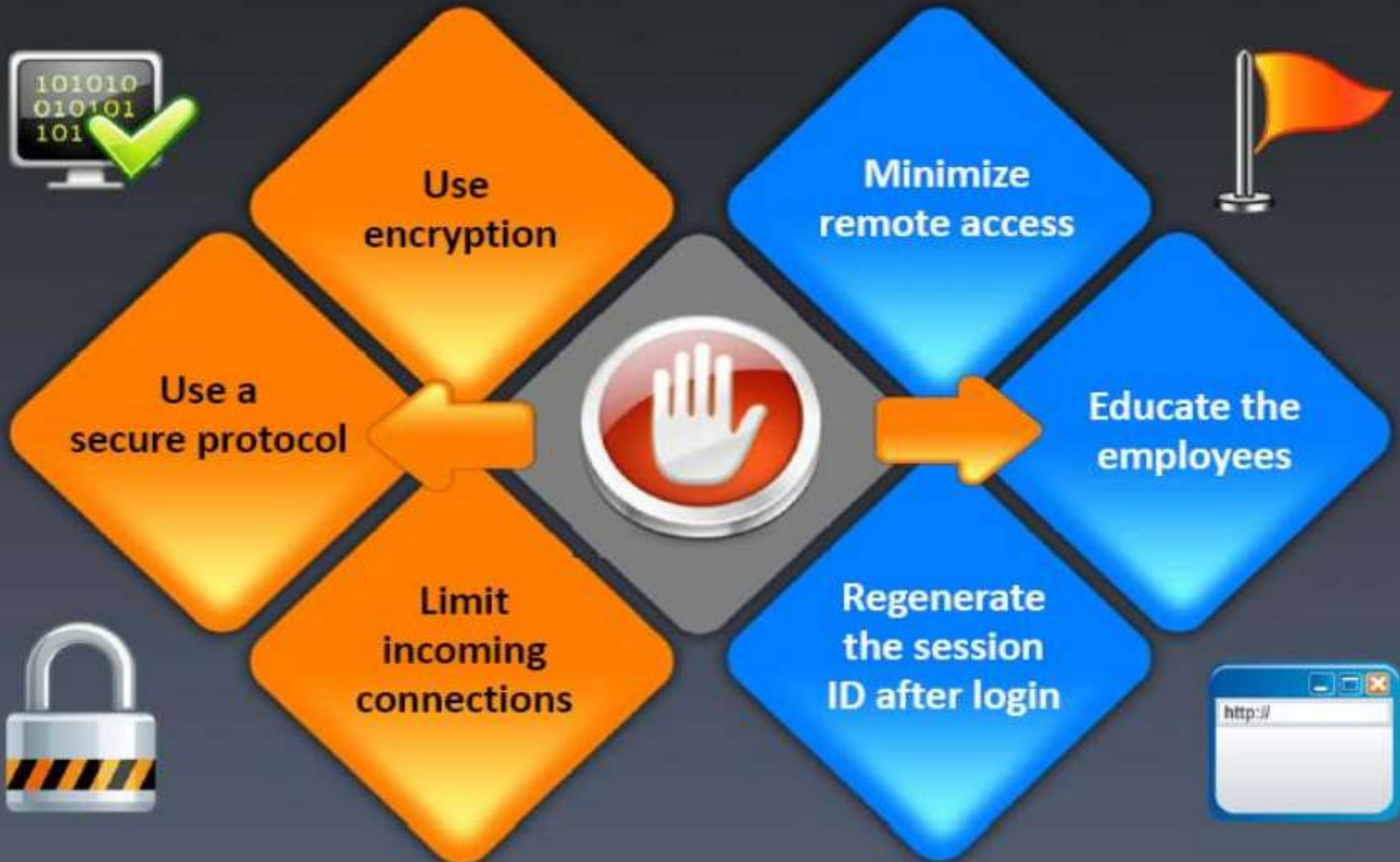
Use string or long random number as a session key



Pass the encrypted data between the users and the web servers

Biện pháp phòng chống

Protecting against **Session Hijacking**



Biện pháp phòng chống

Methods to Prevent Session Hijacking: To be Followed by Web Developers

Reduce the life span of
a session or a cookie

Create session keys with
lengthy strings or random
number so that it is difficult
for an attacker to guess a
valid session key

Expire the session as
soon as the user logs
out

Encrypt the data and
session key that is
transferred between the
user and the web servers

Regenerate the session
id after a successful
login to prevent session
fixation attack

Prevent Eavesdropping
within the network

Biện pháp phòng chống

Methods to Prevent Session Hijacking: To be Followed by Web Users

Do not click on the links that are received through **mails or IM's**

Use Firewalls to prevent the **malicious content** from entering the network

Use firewall and browser settings to **restrict cookies**

Make sure that the website is certified by the **certifying authorities**

Make sure you clear **history, offline content, and cookies** from your browser after every confidential and sensitive transaction

Prefer https, a secure transmission, rather than http when transmitting **sensitive and confidential data**

Logout from the browser by **clicking on logout** button instead of closing the browser

Biện pháp phòng chống

Defending against **Session Hijack Attacks**



Use encrypted protocols that are available at **OpenSSH suite**

Use **strong authentication** (like Kerberos) or peer-to-peer VPN's



Use IDS products or ARPwatch for **monitoring** ARP cache poisoning

Configure the appropriate **internal and external spoof** rules on gateways



Biện pháp phòng chống

Session Hijacking Remediation

1

Defense in depth is a key component of a **comprehensive security plan**



2

Defense in depth is also a key component in **protecting a network** from session hijack attacks



3

Defense in depth is defined as the practice of using **multiple security systems or technologies** to prevent network intrusions



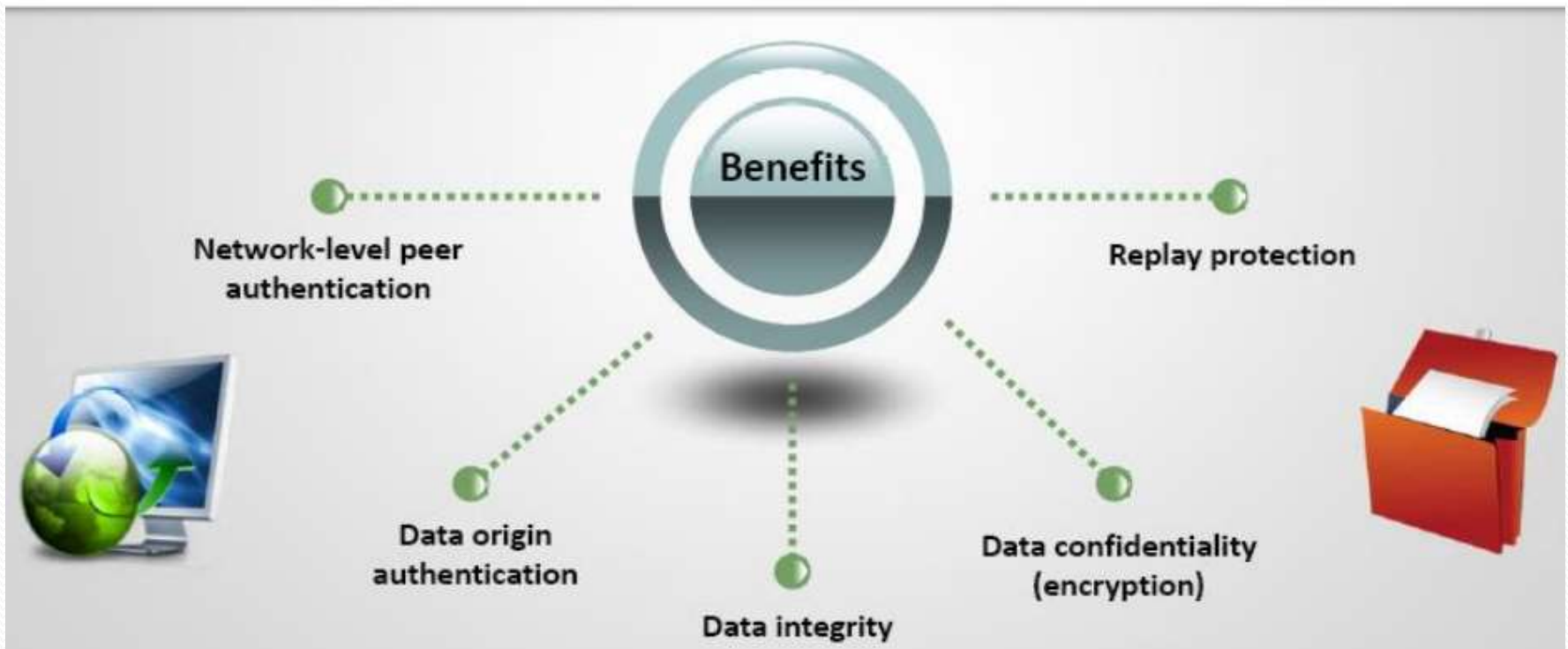
4

The central idea behind the concept is that if one counter measure fails, there are additional levels of protection to **safeguard the network**

Biện pháp phòng chống

IPSec

- IPSec is a set of protocols developed by the IETF to support the **secure exchange of packets at the IP layer**
- It is deployed widely to implement **Virtual Private Networks (VPNs)**



Biện pháp phòng chống

Modes of **IPSec**

Transport Mode

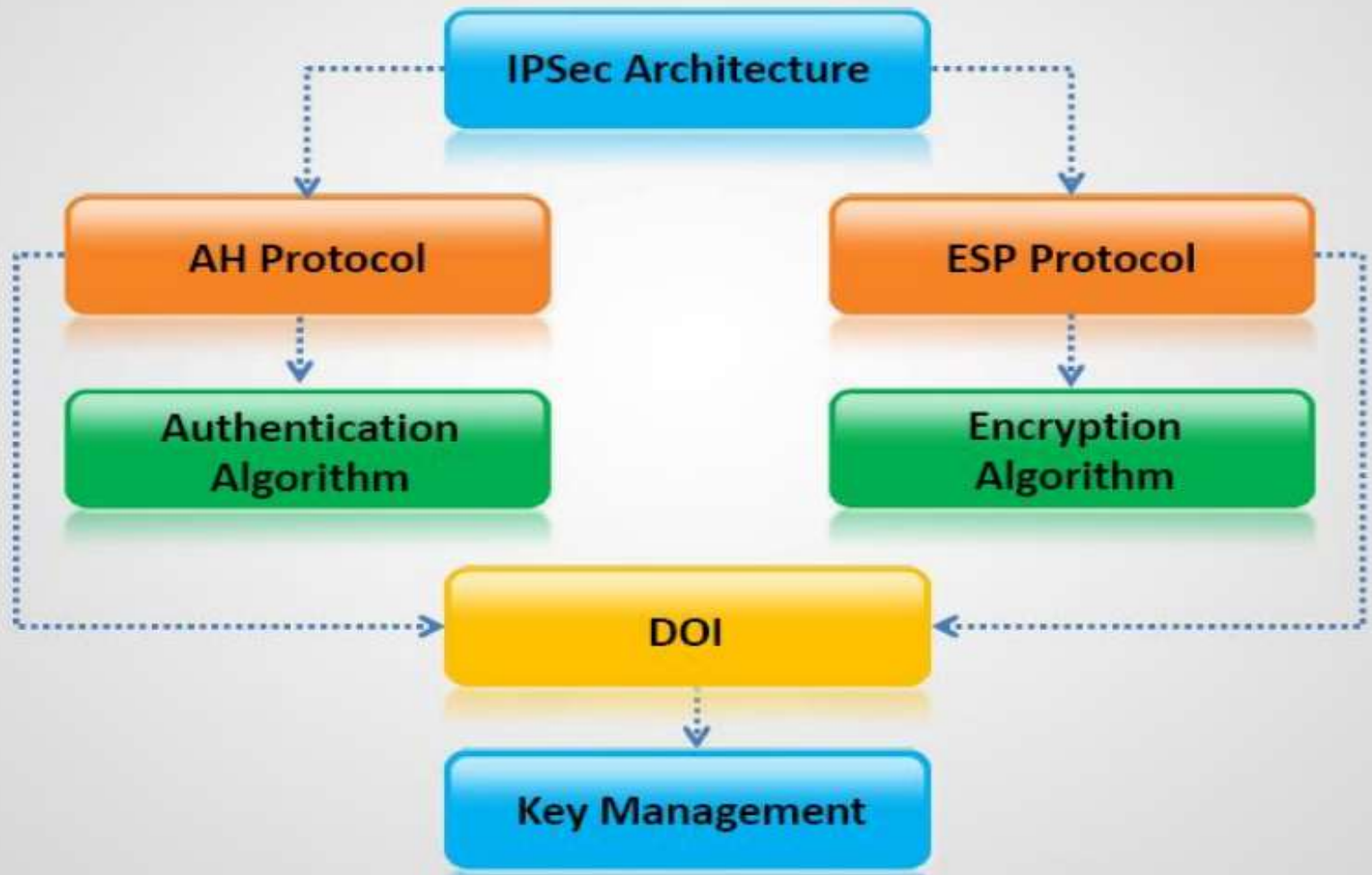
- **Authenticates** two connected computers
- Has an option to **encrypt data transfer**
- Compatible with **NAT**

Tunnel Mode

- **Encapsulates** packets being transferred
- Has an option to **encrypt data transfer**
- Not compatible with **NAT**

Biện pháp phòng chống

IPSec Architecture



Biện pháp phòng chống

IPSec Authentication and Confidentiality



IPSec uses two different security services for authentication and confidentiality

- Authentication Header (AH)
- Encapsulation Security Payload (ESP)

1. **Authentication Header (AH)** provides data authentication of the sender
2. **Encapsulation Security Payload (ESP)** provides both data authentication and encryption (confidentiality) of the sender



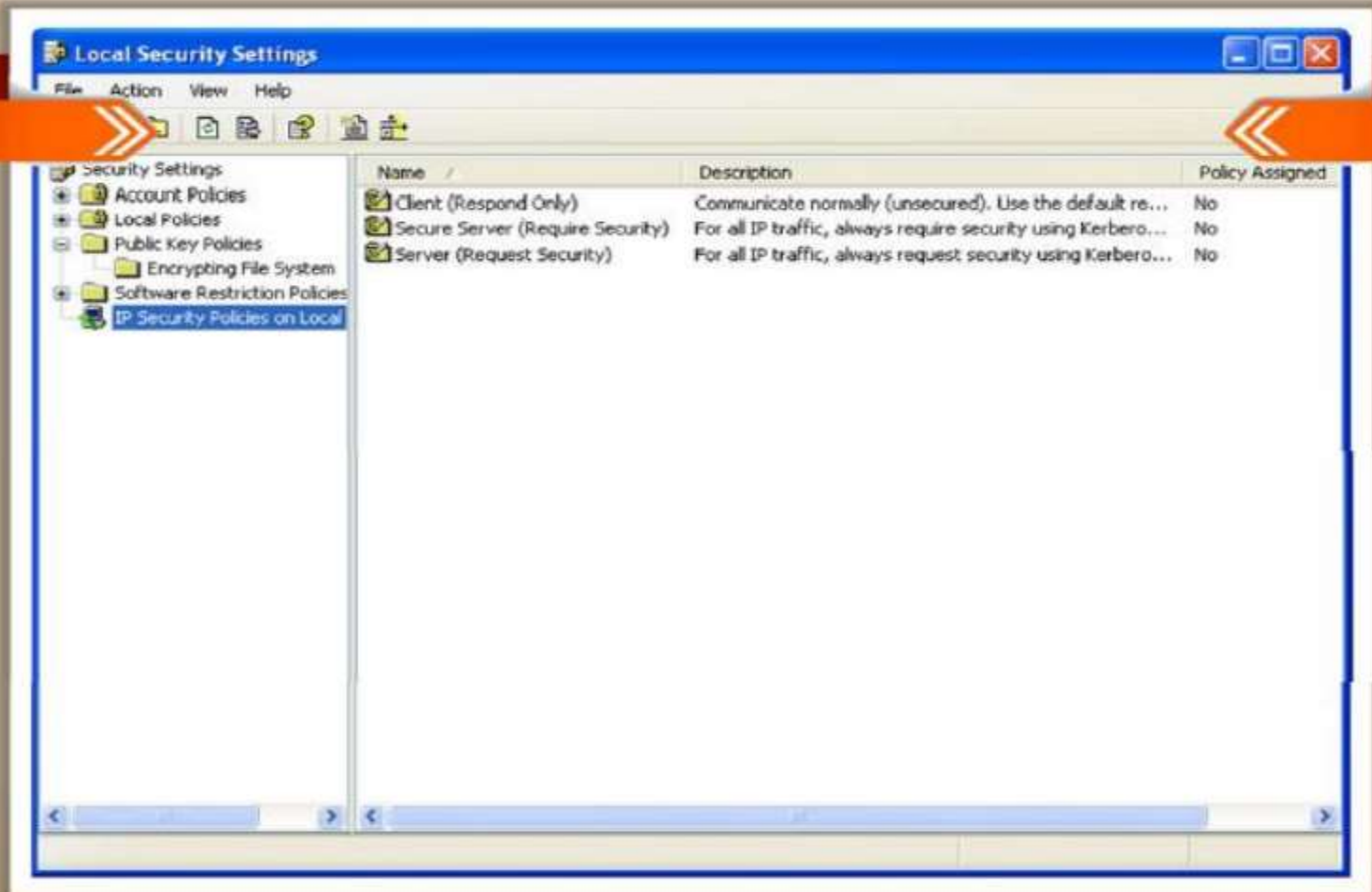
Biện pháp phòng chống

Components of IPSec

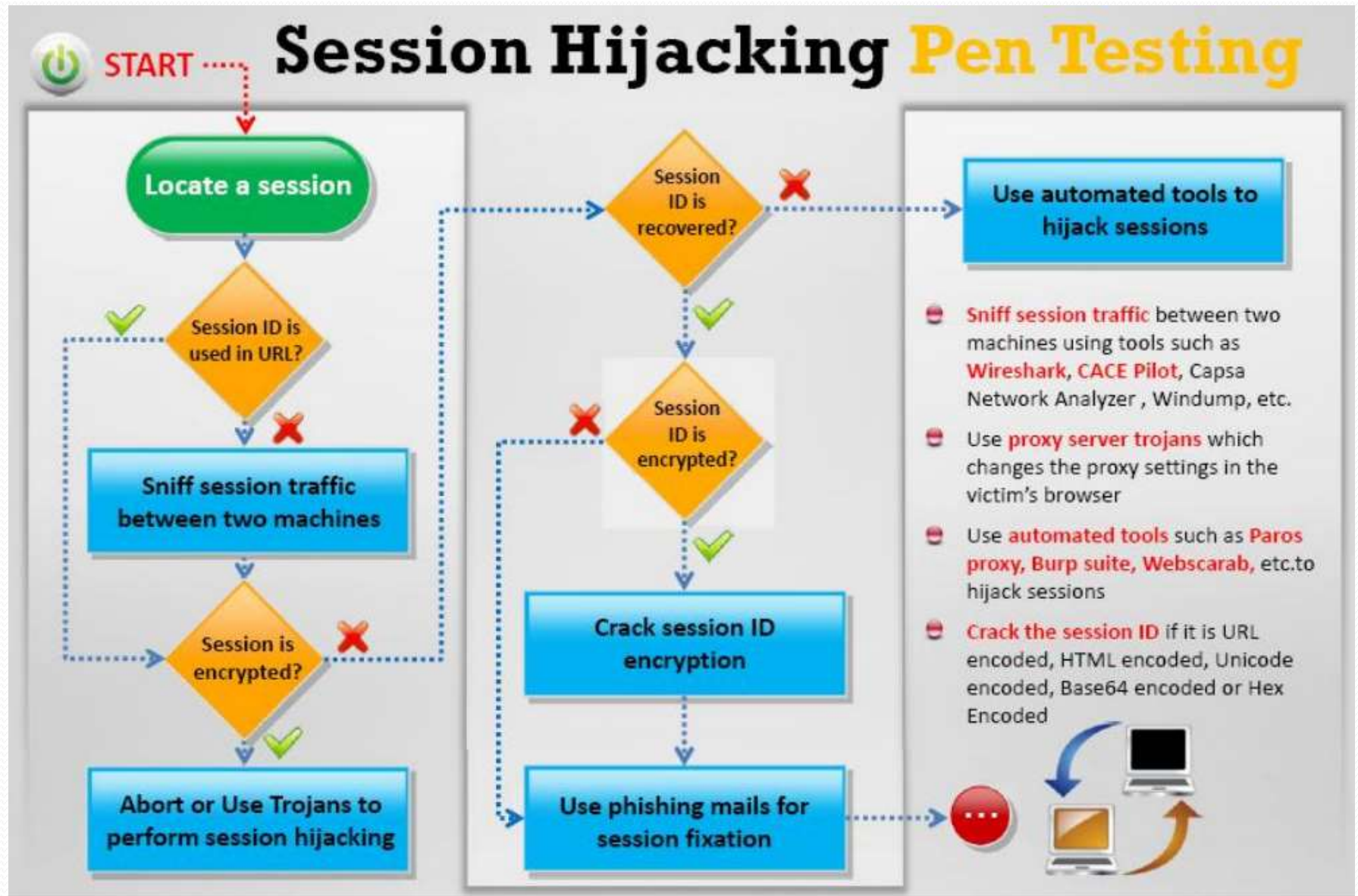


Biện pháp phòng chống

IPSec Implementation



Kiểm thử hệ thống



Kiểm thử hệ thống

Session Hijacking Pen Testing

